

Checklist Audit Clausole Obbligatorie (4 - 10)

Guida operativa d'ispezione per Lead Auditor — Analisi dei requisiti normativi e domandario di verifica per il Sistema di Gestione della Sicurezza dell'Informazione (SGSI).

Clausola 4: Contesto dell'Organizzazione (Context of the Organisation)

4.1 Comprendere l'organizzazione e il suo contesto

Requisito ISO: L'organizzazione deve determinare i fattori interni ed esterni rilevanti per le sue finalità e che influenzano la sua capacità di conseguire i risultati attesi per il proprio SGSI.

DOMANDE CHIAVE DI VERIFICA DURANTE L'AUDIT:

- Quali fattori interni ed esterni sono stati identificati che influenzano il SGSI (es. cultura aziendale, risorse, normative, minacce di settore)?
- Esistono evidenze documentate di questa analisi e della relativa revisione periodica?
- Come sono stati integrati questi fattori nella strategia di sicurezza e nella valutazione dei rischi?

4.2 Comprendere le esigenze e le aspettative delle parti interessate

Requisito ISO: L'organizzazione deve determinare le parti interessate (stakeholder) rilevanti per il SGSI, i loro requisiti e quali di questi requisiti saranno affrontati tramite il SGSI.

DOMANDE CHIAVE DI VERIFICA DURANTE L'AUDIT:

- Chi sono gli stakeholder chiave identificati (clienti, autorità di regolamentazione, fornitori, dipendenti)?
- Quali requisiti di sicurezza hanno questi stakeholder (es. GDPR, PCI-DSS, clausole contrattuali)?
- Come vengono monitorati ed evoluti questi requisiti nel tempo?

4.3 Determinare il campo di applicazione (Scope) del SGSI

Requisito ISO: Nel determinare lo Scope, l'organizzazione deve considerare i fattori 4.1, i requisiti 4.2 e le interfacce/dipendenze. Lo Scope deve essere disponibile come informazione documentata.

DOMANDE CHIAVE DI VERIFICA DURANTE L'AUDIT:

- Qual è il perimetro definito del SGSI (sedi fisiche, reparti, sistemi IT, dati trattati)?
- I confini e le eventuali esclusioni sono chiaramente documentati e motivati?
- Lo Scope è stato formalmente approvato dalla direzione e allineato agli obiettivi aziendali?

4.4 Sistema di gestione della sicurezza delle informazioni

Requisito ISO: L'organizzazione deve stabilire, attuare, mantenere e migliorare continuamente un SGSI, compresi i processi necessari e le loro interazioni.

DOMANDE CHIAVE DI VERIFICA DURANTE L'AUDIT:

- L'organizzazione ha stabilito un SGSI documentato che risponde a tutti i requisiti ISO 27001?
- Quali prove dimostrano che il SGSI è attivo, operativo e continuamente migliorato?
- Ci sono processi formalizzati per gestire le non conformità e le azioni correttive?

Clausola 5: Leadership

5.1 Leadership e impegno

Requisito ISO: L'alta direzione (Top Management) deve dimostrare leadership e impegno rispetto al SGSI assicurando l'integrazione dei requisiti nei processi aziendali, la disponibilità delle risorse e la promozione del miglioramento continuo.

DOMANDE CHIAVE DI VERIFICA DURANTE L'AUDIT:

- In che modo la direzione dimostra impegno concreto (es. partecipazione a comitati, approvazione budget)?
- Come viene integrata la sicurezza nelle strategie complessive dell'azienda?
- Esistono metriche di sicurezza periodicamente rendicontate al Board/Direzione?

5.2 Politica per la sicurezza delle informazioni

Requisito ISO: L'alta direzione deve stabilire una Politica di Sicurezza appropriata alle finalità aziendali, comunicata all'interno dell'organizzazione, disponibile agli stakeholder e riesaminata a intervalli pianificati.

DOMANDE CHIAVE DI VERIFICA DURANTE L'AUDIT:

- È disponibile una copia della Politica per la Sicurezza delle Informazioni firmata e approvata?
- Come viene comunicata a dipendenti, trattatisti e terze parti (es. onboarding, intranet)?
- Quando è stata effettuata l'ultima revisione formale della politica?

5.3 Ruoli, responsabilità e autorità organizzative

Requisito ISO: L'alta direzione deve assicurare che le responsabilità e le autorità per i ruoli rilevanti per la sicurezza siano assegnate, comunicate e comprese all'interno dell'organizzazione.

DOMANDE CHIAVE DI VERIFICA DURANTE L'AUDIT:

- Chi è stato designato come responsabile del funzionamento e mantenimento del SGSI (es. CISO / ISMS Owner)?
- Esiste una matrice organizzativa (es. RACI) o Job Description che esplicitino le responsabilità di sicurezza?
- Coloro che ricoprono ruoli di sicurezza hanno l'autorità formale per prendere decisioni operative?

Clausola 6: Pianificazione (Planning)

6.1.1 Azioni generali per affrontare rischi e opportunità

Requisito ISO: Pianificando il SGSI, l'organizzazione deve determinare i rischi e le opportunità da affrontare per garantire che il sistema raggiunga i risultati attesi, prevenga effetti indesiderati e consegua il miglioramento continuo.

DOMANDE CHIAVE DI VERIFICA DURANTE L'AUDIT:

- Qual è il processo aziendale per identificare i rischi e le opportunità del SGSI?
- Esiste una metodologia documentata per condurre la gestione del rischio?
- I referenti chiave delle varie aree aziendali (IT, HR, Legal, Finance) sono coinvolti nell'analisi?

6.1.2 Valutazione dei rischi per la sicurezza delle informazioni (Risk Assessment)

Requisito ISO: L'organizzazione deve definire e applicare un processo di Risk Assessment che stabilisca criteri di rischio accettabili, identifichi le minacce alla Riservatezza, Integrità e Disponibilità (C-I-A) e assegni i relativi Risk Owner.

DOMANDE CHIAVE DI VERIFICA DURANTE L'AUDIT:

- Quale metodologia standard si utilizza (es. ISO 31000, NIST)?
- Come vengono valutati l'impatto e la probabilità di accadimento delle minacce?
- I risultati dell'analisi dei rischi sono documentati in un Registro dei Rischi (Risk Register) aggiornato?

6.1.3 Trattamento dei rischi per la sicurezza delle informazioni (Risk Treatment)

Requisito ISO: L'organizzazione deve definire un processo di trattamento dei rischi, selezionare le opzioni di mitigazione, confrontare i controlli con l'Annex A, produrre la Statement of Applicability (SoA) e formulare un piano approvato dai Risk Owner.

DOMANDE CHIAVE DI VERIFICA DURANTE L'AUDIT:

- Esiste un Piano di Trattamento dei Rischi (Risk Treatment Plan) formalizzato?
- La SoA riporta la motivazione chiara per l'inclusione o l'esclusione di ciascuno dei 93 controlli dell'Annex A?
- I Risk Owner hanno approvato formalmente il piano e accettato i rischi residui?

6.2 Obiettivi di sicurezza delle informazioni e pianificazione per il loro raggiungimento

Requisito ISO: L'organizzazione deve stabilire obiettivi di sicurezza misurabili, coerenti con la politica, monitorati, comunicati e aggiornati a intervalli pianificati.

DOMANDE CHIAVE DI VERIFICA DURANTE L'AUDIT:

- Quali sono gli obiettivi di sicurezza correnti (KPI / KRI) definiti dall'organizzazione?
- Come vengono tracciati, misurati e comunicati i progressi verso il loro raggiungimento?
- Chi è il responsabile assegnato per ciascun obiettivo e quali risorse sono state allocate?

6.3 Pianificazione delle modifiche

Requisito ISO: Quando l'organizzazione determina la necessità di modifiche al SGSI, tali modifiche devono essere effettuate in modo pianificato e strutturato.

DOMANDE CHIAVE DI VERIFICA DURANTE L'AUDIT:

- Come vengono gestite e valutate le modifiche strutturali al SGSI (es. cambi di infrastruttura, acquisizioni)?
- Esiste un processo formale di Change Management che valuti l'impatto sulla sicurezza prima dell'attivazione?

Clausola 7: Supporto (Support)

7.1 Risorse

Requisito ISO: L'organizzazione deve determinare e fornire le risorse necessarie (economiche, umane, tecnologiche) per l'istituzione, attuazione, manutenzione e miglioramento continuo del SGSI.

DOMANDE CHIAVE DI VERIFICA DURANTE L'AUDIT:

- Le risorse attuali allocate sono sufficienti a coprire le esigenze operative del SGSI?
- Come vengono valutati e stanziati i budget dedicati agli strumenti di sicurezza?

7.2 Competence (Competenze)

Requisito ISO: L'organizzazione deve determinare le competenze necessarie delle persone che svolgono attività che influenzano le prestazioni di sicurezza, assicurarsi che siano competenti e conservarne le relative evidenze documentate.

DOMANDE CHIAVE DI VERIFICA DURANTE L'AUDIT:

- Come vengono valutati i requisiti di competenza in fase di selezione e formazione del personale?
- Esistono registri di formazione, certificazioni e attestati conservati a riprova della competenza del team?

7.3 Consapevolezza (Awareness)

Requisito ISO: Le persone che svolgono attività sotto il controllo dell'organizzazione devono essere consapevoli della politica di sicurezza, del loro contributo all'efficacia del SGSI e delle implicazioni derivanti dalla non conformità ai requisiti.

DOMANDE CHIAVE DI VERIFICA DURANTE L'AUDIT:

- Viene erogato un programma regolare di Security Awareness (es. simulazioni di phishing, corsi periodici)?
- I dipendenti comprendono le conseguenze operative e disciplinari delle violazioni di sicurezza?

7.4 Comunicazione

Requisito ISO: L'organizzazione deve determinare le necessità di comunicazione interna ed esterna rilevanti per il SGSI (cosa comunicare, quando, con chi e come).

DOMANDE CHIAVE DI VERIFICA DURANTE L'AUDIT:

- Quali sono i canali e le procedure definite per comunicare incidenti o aggiornamenti di sicurezza?
- Come vengono gestite le comunicazioni ufficiali verso gli organi regolatori (es. Garante Privacy) o i media?

7.5.1 Informazioni documentate — Generalità

Requisito ISO: Il SGSI dell'organizzazione deve includere le informazioni documentate richieste dalla norma ISO 27001 e quelle determinate come necessarie dall'organizzazione per l'efficacia del SGSI.

DOMANDE CHIAVE DI VERIFICA DURANTE L'AUDIT:

- La documentazione minima obbligatoria richiesta dalla norma è presente e strutturata?

7.5.2 Creazione e aggiornamento delle informazioni documentate

Requisito ISO: Creando e aggiornando le informazioni documentate, l'organizzazione deve assicurare un'adeguata identificazione (titolo, data, autore), formato, riesame e approvazione formale.

DOMANDE CHIAVE DI VERIFICA DURANTE L'AUDIT:

- Chi è responsabile della revisione e dell'approvazione delle politiche e delle procedure di sicurezza?
- La documentazione adotta un tracciamento chiaro delle versioni (Version Control)?

7.5.3 Controllo delle informazioni documentate

Requisito ISO: Le informazioni documentate richieste dal SGSI devono essere controllate per assicurarne la disponibilità, l'adeguatezza e un'adeguata protezione da perdita di riservatezza o modifiche non autorizzate.

DOMANDE CHIAVE DI VERIFICA DURANTE L'AUDIT:

- Come viene controllato l'accesso alla documentazione riservata di sicurezza (es. permessi, cifratura)?
- Come viene gestita la conservazione, l'archiviazione e la distruzione dei registri storici?

Clausola 8: Attività Operative (Operation)

8.1 Pianificazione e controllo operativi

Requisito ISO: L'organizzazione deve pianificare, attuare e controllare i processi necessari per soddisfare i requisiti di sicurezza e per attuare le azioni pianificate nella Clausola 6.

DOMANDE CHIAVE DI VERIFICA DURANTE L'AUDIT:

- Esistono procedure operative documentate per la gestione quotidiana dei sistemi e della sicurezza?
- Come viene verificato che i fornitori esterni o i servizi gestiti rispettino i requisiti operativi stabiliti?

8.2 Valutazione dei rischi per la sicurezza delle informazioni (Operativa)

Requisito ISO: L'organizzazione deve eseguire valutazioni dei rischi per la sicurezza delle informazioni a intervalli pianificati o quando si verificano o propongono cambiamenti significativi.

DOMANDE CHIAVE DI VERIFICA DURANTE L'AUDIT:

- Il registro dei rischi viene aggiornato periodicamente o prima dell'introduzione di nuove tecnologie/processi?

8.3 Trattamento dei rischi per la sicurezza delle informazioni (Operativo)

Requisito ISO: L'organizzazione deve attuare il piano di trattamento dei rischi e conservare le informazioni documentate sui risultati ottenuti.

DOMANDE CHIAVE DI VERIFICA DURANTE L'AUDIT:

- Esistono le evidenze pratiche dell'effettiva attuazione delle misure di mitigazione definite nel Risk Treatment Plan?

Clausola 9: Valutazione delle Prestazioni (Performance Evaluation)

9.1 Monitoraggio, misurazione, analisi e valutazione

Requisito ISO: L'organizzazione deve determinare cosa è necessario monitorare e misurare, i metodi applicati, la frequenza ed esaminare l'efficacia complessiva del SGSI.

DOMANDE CHIAVE DI VERIFICA DURANTE L'AUDIT:

- Quali metriche o sistemi di monitoraggio (es. SIEM, report log, SLA) vengono usati per verificare la sicurezza?
- Con quale frequenza vengono analizzati e valutati i risultati delle misurazioni?

9.2.1 Audit interno — Generalità

Requisito ISO: L'organizzazione deve condurre audit interni a intervalli pianificati per fornire informazioni sull'effettiva conformità del SGSI ai propri requisiti e alla norma ISO 27001.

DOMANDE CHIAVE DI VERIFICA DURANTE L'AUDIT:

- Vengono condotti regolarmente audit interni coprendo l'intero Scope del SGSI?
- Gli auditor interni garantiscono l'obiettività e l'indipendenza rispetto ai processi verificati?

9.2.2 Programma di audit interno

Requisito ISO: L'organizzazione deve pianificare, stabilire, attuare e mantenere un programma di audit interno comprendente frequenza, metodi, responsabilità, pianificazione e rendicontazione.

DOMANDE CHIAVE DI VERIFICA DURANTE L'AUDIT:

- Esiste un calendario / programma annuale degli audit interni basato sui rischi dei processi?
- I report degli audit interni vengono documentati, archiviati e trasmessi alla direzione?

9.3.1 Riesame della direzione — Generalità

Requisito ISO: L'alta direzione deve riesaminare il SGSI dell'organizzazione a intervalli pianificati per assicurarne la continua idoneità, adeguatezza ed efficacia.

DOMANDE CHIAVE DI VERIFICA DURANTE L'AUDIT:

- Il Management Review (Riesame della Direzione) viene svolto formalmente con cadenza regolare (es. annuale)?

9.3.2 Input del riesame della direzione

Requisito ISO: Il riesame della direzione deve considerare lo stato delle azioni precedenti, i cambiamenti nei fattori interni/esterni, i KPI di sicurezza, gli esiti degli audit e i risultati delle analisi dei rischi.

DOMANDE CHIAVE DI VERIFICA DURANTE L'AUDIT:

- L'ordine del giorno o il verbale del riesame dimostra la discussione di tutti gli input obbligatori prescritti dalla norma?

9.3.3 Output del riesame della direzione

Requisito ISO: I risultati del riesame della direzione devono includere decisioni relative ad opportunità di miglioramento continuo e ad eventuali esigenze di modifica al SGSI.

DOMANDE CHIAVE DI VERIFICA DURANTE L'AUDIT:

- Quali decisioni formali, approvazioni di risorse o modifiche strategiche sono state verbalizzate nell'ultimo riesame?

Clausola 10: Miglioramento (Improvement)

10.1 Miglioramento continuo

Requisito ISO: L'organizzazione deve migliorare continuamente l'idoneità, l'adeguatezza e l'efficacia del SGSI.

 DOMANDE CHIAVE DI VERIFICA DURANTE L'AUDIT:

- Quali iniziative di miglioramento e ottimizzazione sono state intraprese a seguito dei risultati d'audit o di riesame?

10.2 Non conformità ed azioni correttive

Requisito ISO: In caso di non conformità, l'organizzazione deve reagire, valutare le cause radice (Root Cause Analysis), attuare azioni correttive per evitarne il ripresentarsi e riesaminarne l'efficacia.

 DOMANDE CHIAVE DI VERIFICA DURANTE L'AUDIT:

- Esiste un registro formalizzato per la gestione delle Non Conformità e degli incidenti?
- Come viene condotta la Root Cause Analysis per identificare la causa scatenante dei problemi?
- Viene effettuata una verifica a distanza di tempo per confermare che l'azione correttiva abbia risolto definitivamente la problematica?